Response to NIST NCCoE Concept Paper: "Accelerating the Adoption of Software and AI Agent Identity and Authorization"

Submitted by: ZeroBiometrics
Date: April 1, 2026
Contact: David Burnett, Head of Product — david.burnett@zerobiometrics.ai
In response to: NIST NCCoE Concept Paper, Draft February 2026
Comment submission: AI-Identity@nist.gov
Attachment: ZeroBiometrics Technical White Paper — ZeroSentinel: A Standards-Aligned Cryptographic Human-Authorization Layer for Agentic AI

Why ZeroBiometrics Is Responding

The NCCoE's concept paper asks a question with global consequences: how should AI agents — systems that exercise autonomous judgment and act with delegated human authority — be identified, authenticated, authorized, audited, and governed?

ZeroBiometrics is responding because we possess a specific, certified technical capability directly relevant to this question. Our core technology, ZeroFace, derives ECC private keys from facial biometric entropy — producing stable cryptographic keypairs without storing private key material. The same face produces the same key every time; no key is ever persisted. This capability is certified under ISO/IEC 30136:2018 by BixeLab (ISO/IEC 17025 accredited, Australia), validating both irreversibility and unlinkability. We can sign X.509 certificates where the human's biometric is the signing key — not a gatekeeper for a stored key, but the key itself — optionally endorsed by identity document verification (passport, driver's license, Real ID) to bind the cryptographic identity to a verified civil identity.

If you can cryptographically prove which specific, verified human authorized an action — not "someone with this device" but "this individual, identity-verified, biometrically present at signing time" — that is a natural root of trust for bootstrapping an AI authorization control plane. Every delegation credential, every scope boundary, every revocation in the chain traces back to a biometrically-proven human identity with strong cryptographic guarantees.

We believe this model provides benefits important enough to the safe and governed use of AI that we have built a product around it. ZeroSentinel is a fully specified cryptographic human-authorization layer for agentic AI, built on this biometric root of trust and on internet-scale proven standards: X.509, OAuth 2.0, MCP, SCIM, and NGAC (INCITS 565-2020). The attached white paper provides the complete architecture, threat model, and standards self-assessment. Whether ZeroSentinel is commercially successful is irrelevant to whether its design — and the standards-aligned patterns it demonstrates — is responsive to this RFI. We encourage the NCCoE to evaluate the architecture on its merits, independent of any particular vendor's implementation.

The need for an effective control plane that cryptographically binds humans and AI agents is not an enterprise IT concern — it is an issue that affects every person and every business, not only in the United States but throughout the world. Cryptographic non-repudiation for identities, permissions granted, and actions taken is not a nice-to-have. It is a must-have — the only mechanism capable of producing a tamper-proof, immutable record of who authorized what, with what scope, and what the agent did with that authority. "Trust the platform" is not a viable alternative when most humans do not yet understand the difference between traditional software and agentically-driven systems that exercise autonomous judgment — and when documented instances exist of AI agents becoming sufficiently goal-driven that they actively attempt to circumvent the controls meant to govern them. When the entity being governed is capable of reasoning about its own governance, that governance must be cryptographic and external to the agent, not policy-based and dependent on the agent's cooperation. The standards to build this already exist and are proven to operate at internet-scale. The gap is

applying them to the specific problem of binding human authorization to agent action with an unbroken cryptographic chain. That is what this concept paper asks, and that is what this response addresses.

ZeroFace is ISO/IEC 30136-certified, and is deployed commercially. ZeroSentinel's architecture is fully specified with production-ready components at varying stages of maturity. The technical white paper, provided under separate cover, provides the complete architecture, threat model, and mapping to essential standards, including those specifically mentioned in the RFI.

Focus Area Alignment Summary

NIST Focus Area	ZeroBiometrics Approach	Standards Used
1. Identification	X.509 agent identity certificate (ZeroAgent) with proof-of-possession via mTLS. SCIM integration for agent and staff lifecycle management. Layered lifetimes: long-lived human identity, medium-lived agent identity, short-lived task-scoped delegation.	X.509, mTLS, SCIM (RFC 7643/7644)
2. Authentication	mTLS agent authentication combined with delegation credential validation. Human authentication via ISO/IEC 30136-certified biometric key reconstruction — no stored private key.	X.509, mTLS, ISO/IEC 30136
3. Authorization	Human-signed delegation certificate (ZeroGrant) with machine-enforceable OID policy extensions (see attached white paper, Appendix B). Policy cryptographically fixed at signing time. NGAC graph with human-signed mutations — no mutable policy in enforcement path.	X.509 OIDs, OAuth 2.0 (RFC 8705), NGAC (INCITS 565)
4. Access Delegation	Biometric signing ceremony binds human intent to agent authority. Delegation credentials specify scope, audience, time bounds, and data flow constraints. Agent-to-agent sub-delegation with scope-narrowing invariant.	X.509, FIDO-inspired ceremony
5. Logging & Transparency	Enforcement proxy (ZeroIntent) mediates all agent-to-service interactions — audit completeness by architecture, not by agent cooperation. Entries include delegation fingerprint, request hash, policy evaluation, and outcome.	Append-only audit log, cryptographic fingerprints
6. Data Flow Tracking	Classification-aware enforcement at the proxy layer. Tool-level sensitivity classifications in the delegation credential. Independent ephemeral agent for contextual aggregation assessment. Open DLP integration hook for content-level inspection. Cross-tool flow constraints enforced, not just logged.	X.509 OID extensions (DATA-FLOW-POLICY)
Prompt Injection	Three-layer defense-in-depth: (1) scope-bounded delegation limits blast radius, (2) open integration hook for prompt injection screening engines at the enforcement proxy, (3) data flow enforcement blocks exfiltration even if injection succeeds.	Open hook API — vendor-neutral

---

General Comments

We commend NIST and the NCCoE for framing the agentic identity challenge in terms of cryptographic identity, delegated

authorization, and verifiable scope. This framing correctly identifies the control-plane problem: AI agents act with authority, and there is currently no standardized mechanism to cryptographically bind that authority to the human who granted it, scope it to specific actions and audiences, independently verify it, and revoke it.

We offer four observations about gaps in the concept paper's current framing that we believe the demonstration project should address:

1. The stored-key assumption — and the FIDO assumption — are structural vulnerabilities. The concept paper references conventional PKI, SPIFFE/SPIRE, and OAuth as candidate standards. All of these assume that signing keys are generated and stored — in HSMs, secure enclaves, or key vaults. A compromised key store enables undetectable impersonation of human authorization.

The natural response is to suggest FIDO/WebAuthn (FaceID, TouchID, Windows Hello) as the human authentication layer. FIDO provides strong authenticator assurance and has earned its widespread adoption. However, in the specific context of AI agent delegation, FIDO as deployed has a limitation worth examining: **FIDO proves device-holder presence, not identity.** A platform authenticator confirms "I have seen this face before on this device" — it does not confirm whose face it is. The biometric is a local gatekeeper that unlocks a stored private key in a secure enclave; the biometric itself is not a cryptographic participant. If someone enrolls their biometric on a stolen or compromised device, FIDO authenticates them as the original user. For the question "which specific human authorized this AI agent?" — FIDO answers "someone who has this device," not "David Burnett."

The demonstration project should evaluate biometric key derivation, where the human's signing key is reconstructed from biometric entropy at signing time and never persisted — the biometric IS the key, not a gatekeeper for one. This eliminates the stored-key attack class entirely, but it also enables an identity assurance model that FIDO cannot express:

- **Biometric key derivation alone** proves the same person signed both times — cryptographic continuity without stored keys.
- **Biometric key derivation + IDV endorsement** proves the same person signed AND that person's identity has been verified by document review (passport, Real ID). The delegation credential now carries cryptographic proof of both presence and identity — not just "a face was seen" but "this specific face, belonging to this verified individual, produced this key."
- **Biometric key derivation + IDV + platform authenticator** provides cryptographic triangulation: three independent signals (biometric-derived key, identity verification evidence, and device-local biometric match) all corroborating the same human's presence and identity.

This layered assurance model is compatible with SP 800-63-4 identity assurance levels and is independently validated by ISO/IEC 30136:2018 certification (see attached white paper, Appendix C). No respondent building on stored-key PKI or FIDO alone can offer these properties, because the underlying technology — cryptographic key derivation from biometric entropy with both irreversibility and unlinkability — is architecturally distinct from biometric-gated key storage.

2. Privacy is absent from the current framing. The concept paper is enterprise-centric: a single agent identity propagates across all systems it accesses. As AI agents increasingly act on behalf of individuals across organizational boundaries — personal assistants accessing healthcare, financial, and workplace services — cross-service identity correlation becomes a privacy liability. The demonstration project should consider pairwise-pseudonymous delegation architectures, consistent with the privacy principles in FIDO2/WebAuthn, where a relying party can verify that a delegation is valid without learning the human's identity at other services. (See attached white paper, "Pairwise Pseudonymity.")

3. Data flow enforcement, not just tracking. Focus Area 5 frames data flow as a tracking problem. In practice, the critical risk is that agents authorized for multiple tools can combine permissions to exfiltrate data — an agent with read access to sensitive records and write access to email can combine those capabilities in ways that individual tool permissions do not control. The demonstration project should evaluate classification-aware enforcement models where cross-tool data flow constraints are embedded in the delegation credential and enforced at the proxy layer, not merely logged after the fact. (See attached white paper, Appendix B: DATA-FLOW-POLICY OID.)

4. Agent governance is most effective when agent behavior is driven by inspectable artifacts. The concept paper addresses how to control what agents are authorized to do, but does not address how agents acquire the context to do it effectively — or how that context relates to governance. We observe that the most auditable and governable agents are those whose operating rules, task definitions, and domain constraints are defined in structured, semantically-rich, machine-parseable specifications rather than encoded as opaque fine-tuned model weights. A delegation credential that references a specific, versioned specification is meaningfully auditable — a regulator or compliance officer can inspect exactly what the agent was told to do. A delegation credential that references a fine-tuned model is a black box with an access control wrapper. For the use cases this concept paper describes — internal enterprise workflows requiring policy conformance, audit trails, and regulatory compliance — structured specifications are not merely preferable; in regulated contexts (SOX Section 404, HIPAA, GDPR Article 22), auditable documentation of automated decision-making processes is a compliance requirement that opaque model weights cannot satisfy.

Responses to Focus Area Questions

1. General Questions

What enterprise use-cases are organizations currently using agents for?

We observe three deployment patterns in enterprise AI agent adoption:

- **Developer tooling**: AI agents with access to code repositories, CI/CD pipelines, cloud infrastructure, and monitoring systems. These agents operate with broad permissions inherited from the developer's service accounts, with no mechanism to scope authority to a specific task or time window.
- **Workflow automation**: Agents that access email, calendars, CRM systems, and document stores on behalf of knowledge workers. The authorization gap here is acute — these agents access sensitive data across multiple services with no cryptographic binding to the human who authorized the access.
- **Security operations**: Agents that analyze logs, triage alerts, and take remediation actions. The non-repudiation requirement is highest in this category, as agent actions may have compliance and audit implications.

In all three patterns, the common gap is the same: no verifiable, scoped, revocable link between the agent's actions and a specific human's authorization.

What risks worry you about agents?

The risk taxonomy should distinguish between risks that authorization can address and risks it cannot:

- **Authorization-addressable**: Unauthorized scope (agent exceeds intended authority), unauthorized delegation (agent grants sub-agents authority the human did not approve), unrevocable access (no mechanism to halt agent activity instantly), unattributable actions (no cryptographic proof of who authorized what), unauthorized data exfiltration (cross-tool data flow that violates policy), proprietary data leakage (content-level data loss).
- **Not authorization-addressable**: Prompt injection (confused intent within authorized scope), model hallucination, alignment failures. These are complementary concerns that benefit from defense-in-depth at the enforcement layer (see Section 6).

This distinction is important for scoping the demonstration project. Conflating authorization with alignment risks producing a system that does neither well.

What support are you seeing for new protocols such as Model Context Protocol (MCP)?

MCP adoption is accelerating rapidly. MCP is significant for this project because it creates a natural enforcement point: an MCP-aware proxy can validate authorization credentials on every tool invocation without modifying either the AI agent or the

downstream tool server. ZeroSentinel's enforcement gateway, ZeroIntent, operates as an MCP proxy — validating human-signed delegation credentials on each tool call and issuing appropriately scoped OAuth tokens to the downstream service. This architecture demonstrates that authorization enforcement can be deployed at the protocol layer without requiring ecosystem-wide adoption before the system is useful.

What current or roadmap technology does your organization have that supports agents?

ZeroSentinel is a standards-aligned cryptographic human-authorization layer for agentic AI. Its architecture includes:

- **ZeroCert**: X.509 certificate containing the public portion of a biometrically-derived IdentityKey. The private key is never stored — it is reconstructed from face entropy at signing time. Certified under ISO/IEC 30136:2018 by BixeLab.
- **ZeroGrant**: A delegation certificate signed by the human in a biometric ceremony, specifying the agent's authorized scope, audience, time bounds, and data flow constraints as machine-readable OID extensions. The certificate IS the policy. (See attached white paper, Appendix B for the full OID schema.)
- **ZeroIntent**: A proxy enforcement gateway that validates every agent request against the signed ZeroGrant, provides open integration hooks for prompt injection screening and DLP, and issues sender-constrained OAuth 2.0 tokens (RFC 8705) to downstream services. Neither the agent nor the service requires modification.
- **ZeroAgent**: X.509 agent identity certificate with proof-of-possession, validated via mTLS. Lifecycle managed via SCIM.

The system builds on X.509, OAuth 2.0/2.1, MCP, SCIM, and NGAC (INCITS 565-2020). It operates at the protocol layer: deployment is a proxy configuration, not a platform migration. The complete architecture, threat model, and standards self-assessment are provided in the attached white paper.

What standards exist, or are emerging, to support identity and access management of agents?

The standards listed in the concept paper — OAuth 2.0/2.1, OIDC, SPIFFE/SPIRE, SCIM, NGAC — are necessary but not sufficient. They were designed for human-interactive or machine-to-machine scenarios. The gap specific to agentic AI is *delegation with scope*: binding a machine credential to a human's explicit, bounded authorization.

X.509 certificate extensions (OIDs) provide a standards-based mechanism to embed machine-enforceable policy directly in delegation credentials. This approach — policy-in-certificate rather than policy-in-engine — ensures that authorization scope is cryptographically fixed at signing time and cannot be expanded by a compromised policy engine or a misconfigured runtime. We recommend the demonstration project evaluate this pattern alongside the traditional policy-engine approach. (See attached white paper, Appendix B for our OID schema implementation.)

OIDC is a natural extension for the authentication layer, complementing X.509/mTLS for web-based flows where browser-compatible identity protocols are required. ZeroSentinel's architecture is compatible with OIDC integration for these scenarios.

2. Identification

How might agents be identified in an enterprise architecture?

Agent identity should be cryptographic, not nominal. An X.509 agent identity certificate with proof-of-possession (the agent proves it holds the private key corresponding to the certificate) provides a foundation that is compatible with existing enterprise PKI infrastructure. Agent identity metadata — model version, runtime environment, organizational affiliation — can be encoded as certificate extensions.

Agent lifecycle management — provisioning, updates, deprovisioning — should integrate with existing enterprise identity infrastructure via SCIM (RFC 7643/7644). This allows enterprises to manage agent identities using the same provisioning workflows they use for human identities. Critically, deprovisioning an agent via SCIM should trigger revocation cascade: not just revoking the agent's identity certificate, but invalidating all active delegation credentials, tokens, and sub-delegations derived from that identity.

Should agent identity metadata be ephemeral or fixed?

Different layers should have different lifetimes. Agent identity (the certificate identifying the agent itself) should be medium-lived. Delegation authority (the credential binding the agent to a specific human authorization) should be short-lived and task-scoped. Human identity (the root of the delegation chain) should be long-lived. This layered lifetime model is architecturally correct, not a compromise — it reflects the different trust semantics of each layer.

Should agent identities be tied to specific hardware, software, or organizational boundaries?

This splits into two architecturally distinct cases. For enterprise-owned AI agents, runtime attestation is tractable: secure boot, TPM/TEE, model hash verification. For commercial AI services (agents hosted by Anthropic, OpenAI, Google, etc.), runtime attestation must come from the AI provider — it is outside the deploying enterprise's control. The demonstration project should address both cases and should not assume that all agents run in environments the enterprise controls.

3. Authentication

What constitutes strong authentication for an AI agent?

mTLS with an X.509 agent certificate, combined with delegation credential validation, proves both "who is this agent" (identity) and "what is this agent authorized to do" (delegation). The combination is stronger than either property alone. Authentication without authorization verification is insufficient in agentic contexts — an authenticated agent may still be acting outside its authorized scope.

How do we handle key management for agents? Issuance, update, and revocation?

For agent keys, standard certificate lifecycle management applies, integrated with enterprise provisioning via SCIM. The more significant key management challenge is on the *human* side of the delegation: the human's signing key. Conventional approaches (HSM, secure enclave, password-protected keystore) all share a common vulnerability — the key can be stolen, and a stolen key enables undetectable impersonation of the human's authorization.

Biometric key derivation eliminates this class of attack. The human's signing key is an ephemeral ECC keypair reconstructed from biometric entropy at signing time. There is no stored private key to steal, no key file to exfiltrate, no passphrase to phish. The human IS the key, not the holder of one. This property is independently validated by ISO/IEC 30136:2018 certification (see attached white paper, Appendix C).

Revocation should cascade through the delegation chain, consistent with SP 800-207 zero-trust principles. Revoking the human's root credential should instantly invalidate all derived delegation credentials, all issued tokens, and all sub-delegations. This requires that each credential's validity depends on its parent's validity — a structural property, not a runtime policy check.

4. Authorization

How can zero-trust principles be applied to agent authorization?

Consistent with SP 800-207, deny by default, verify every request. An enforcement proxy that sits between the agent and downstream services and validates the agent's delegation credential on every tool invocation implements zero-trust at the agent-service boundary. The critical addition for agentic AI is that the verification must check not only "is this agent authenticated" but "does this agent's current delegation authorize this specific action, for this specific service, at this time."

Can authorization policies be dynamically updated when an agent context changes?

This question reveals a fundamental design tension. If policy is mutable at runtime, a compromised policy engine can silently expand an agent's permissions. ZeroSentinel addresses this by moving policy evaluation to signing time: the human evaluates and approves the policy, and the output is cryptographically bound into the delegation credential. The

enforcement layer validates the signed artifact, not a runtime policy query. A compromised policy engine cannot expand permissions on existing delegations.

Dynamic context changes (the agent accesses a new data source, session sensitivity increases) should be handled by enforcement constraints in the credential itself — for example, classification-aware data flow rules that monotonically restrict what the agent can do as session sensitivity accumulates — not by mutating the delegation after issuance.

How do we determine sensitivity levels of data when aggregated by an agent?

This is the mosaic effect problem: individually innocuous data sources that, in combination, produce sensitive intelligence. An agent authorized to read HR records and also read calendar data could infer personnel patterns that neither data source reveals alone.

Static aggregation rules encoded in the delegation credential address known combinations, but contextual assessment requires reasoning about *why* a specific combination is sensitive. Our approach uses an independent ephemeral agent — short-lived, purpose-scoped, spawned by the enforcement proxy rather than by the primary agent — that assesses sensitivity based on the session's accumulated data flow history and structured, semantically-rich, machine-parseable specifications defining the classification rules. The primary agent cannot influence this assessment because it does not control, see, or interact with the classification agent. This is the same structural independence principle used for independent quality assurance in software development: the entity that produced the work product should not be the entity that evaluates its compliance.

Session classification should be monotonically increasing: once an agent accesses data at a given sensitivity level, the session remains at that level or higher. (See attached white paper, Appendix B: DATA-FLOW-POLICY OID.)

How do we establish "least privilege" for an agent, especially when its required actions might not be fully predictable when deployed?

The concept paper correctly identifies this as a hard problem. Our approach is to make least privilege *human-decidable*: the delegation credential enumerates specific tools, specific services, and specific data classifications the agent may access. Anything not explicitly authorized is denied. When the agent encounters a task requiring authority it does not possess, it must request a new delegation from the human — a new biometric signing ceremony, not a runtime policy expansion.

The task definition itself — what the agent should do, which tools that requires, what data it will touch — is most effectively expressed as a structured, semantically-rich, machine-parseable specification that the delegation credential references. Domain experts working with AI assistants can produce these specifications conversationally, making least-privilege scoping accessible without requiring security engineering expertise for every delegation.

How might an agent convey the intent of its actions?

Intent is best conveyed by external, inspectable artifacts rather than by the agent's own claims. When an agent's task, constraints, and operating rules are defined in structured, semantically-rich, machine-parseable specifications referenced by the delegation credential, the agent's intent is transparent to any party that can read the specification — the human who authorized it, the enforcement layer that validates it, the auditor who reviews it after the fact, and the screening tools that evaluate whether the agent's requests are consistent with its stated purpose.

This is fundamentally more auditable than approaches that infer intent from agent behavior or rely on the agent to self-report its goals.

How do we handle delegation of authority for "on behalf of" scenarios?

The delegation credential itself is the "on behalf of" artifact. It is signed by the human's biometrically-derived key and issued to the agent's public key. The combination of signatures cryptographically proves that a specific human, at a specific time, authorized a specific agent to perform specific actions for a specific audience. The relying party can verify this independently without trusting the agent's claims.

For agent-to-agent delegation (an orchestrating agent invoking sub-agents), the delegation chain extends one level deeper: the orchestrating agent can issue a sub-delegation granting a strict subset of its own authority. The critical invariant is that scope can only narrow through the delegation chain, never expand. When the orchestration is driven by structured, semantically-rich, machine-parseable specifications that decompose a task into sub-tasks with defined scope, the sub-delegation boundaries come from the specification rather than from the orchestrating agent's judgment — providing both auditability and determinism. The human controls the maximum delegation depth via delegation policy.

How do we bind agent identity with human identity to support "human-in-the-loop" authorizations?

Human-in-the-loop should be a cryptographic ceremony, not a policy configuration. The delegation credential is the binding artifact: signed by the human's key, issued to the agent's key, carrying machine-enforceable policy. This provides cryptographic non-repudiation — the human cannot deny having authorized the delegation, because only their biometric can produce the signing key.

5. Auditing and Non-Repudiation

How can we ensure that agents log their actions in a tamper-proof and verifiable manner?

The key insight is that audit completeness should be an architectural property, not an agent cooperation requirement. If the enforcement proxy mediates every agent-to-service interaction, then the audit trail at the proxy is complete by construction — the agent cannot take actions that bypass the audit log because it cannot bypass the proxy. Each audit entry should include the delegation credential fingerprint, request hash, policy evaluation result, and outcome. This creates a verifiable chain from the human's authorization through every action the agent took under that authorization.

How do we ensure non-repudiation for agent actions and binding back to human authorization?

A delegation credential signed by the human's biometrically-derived key provides cryptographic non-repudiation. The signing key can only be reconstructed from the human's biometric — a property independently validated by ISO/IEC 30136:2018 certification (irreversibility tests confirm the key cannot be derived from stored data; see attached white paper, Appendix C). Therefore, a valid signature proves that a specific human was biometrically present when the delegation was created. This is not log-based non-repudiation (which depends on log integrity) — it is cryptographic non-repudiation bound to biometric presence.

6. Prompt Injection Prevention and Mitigation

What controls help prevent both direct and indirect prompt injections?

Authorization and prompt injection are complementary but distinct concerns. An authorization layer prevents agents from taking *unauthorized* actions — actions outside the scope of the human's delegation. Prompt injection causes agents to take *unintended* actions that may fall within their authorized scope but were not the human's intent.

Rather than treating these as separate problems, the enforcement proxy provides a natural integration point for defense-in-depth. Because ZeroIntent mediates all agent-to-service traffic bidirectionally, it can host open, non-proprietary integration hooks for prompt injection screening engines — LLM-based classifiers, rule-based systems, or any enterprise-preferred detection tooling. Screening operates in both directions: inbound (detecting direct injection in agent requests before they reach downstream services) and outbound (detecting indirect injection in tool responses before they reach the agent). ZeroBiometrics provides the architectural enforcement point; enterprises connect their preferred detection engine. This follows the same principle as our approach to liveness detection — a specialized domain served by dedicated vendors through open integration.

After prompt injection occurs, what controls/practices can minimize the impact of the injection?

Three layers constrain the damage:

1. **Scope-bounded delegation**: The agent can only take actions authorized by the ZeroGrant. A successful injection cannot cause the agent to exceed its delegation scope because the enforcement proxy validates every request against the signed credential.
2. **Classification-aware data flow enforcement**: Even if an injection causes the agent to attempt data exfiltration within its authorized tool set, flow constraints in the delegation credential can block the exfiltration at the proxy layer. An agent authorized to read sensitive records and send email cannot combine those permissions to exfiltrate data.
3. **Independent content inspection**: Open DLP integration hooks at the enforcement proxy enable enterprise DLP solutions to inspect request and response content for proprietary data, PII, or other sensitive material — regardless of whether the request was prompted by injection or legitimate intent.

No single layer solves prompt injection. The combination — authorization scope bounding the attack surface, flow enforcement blocking exfiltration paths, and content inspection catching sensitive data — creates a defense-in-depth model at the enforcement point.

Comments on Use Cases

All three proposed use cases — workforce efficiency, security operations, and software development — are relevant and well-chosen. We offer two observations:

Structured specifications as the bridge between authorization and agent effectiveness. All three use cases describe internal enterprise workflows where agents must operate within defined constraints — policy rules, security procedures, development standards. These constraints are most effective when expressed as structured, semantically-rich, machine-parseable specifications that both the agent and the authorization layer can reference. The delegation credential defines what the agent is *permitted* to do; the specification defines what the agent is *intended* to do and *how*. Together they form a complete governance model. Notably, structured specifications can be produced by domain experts working conversationally with AI assistants — no custom model training required. This makes agent deployment accessible to enterprises that lack ML engineering teams, at any scale.

Personal AI agent authorization. The concept paper scopes the project to enterprise use cases where "visibility can be maintained over agents and the systems they access." However, the fastest-growing deployment of AI agents is in the personal context — individuals using AI assistants that access their email, banking, healthcare portals, and social media on their behalf. These agents act across organizational boundaries with no central enterprise authority.

Personal AI agent authorization requires the same cryptographic properties (delegation, scope, revocation, non-repudiation) but adds a privacy requirement that the enterprise model does not: the human's identity at one service must not be correlatable with their identity at another service. Pairwise-pseudonymous delegation credentials — where each service receives a unique, unlinkable identifier for the same human — address this requirement while preserving full authorization verifiability.

We recommend the demonstration project consider the personal use case in a future iteration, as the architectural requirements it surfaces (privacy-by-design, no central authority, cross-organizational delegation) will eventually apply to enterprise deployments as well.

Collaboration

ZeroBiometrics is willing to engage with the NCCoE in whatever manner is most useful to the demonstration project. We recognize that NIST's objective is to advance the state of the art for the benefit of the broader community, and we are prepared to support that objective on the NCCoE's terms.

Specifically, we would welcome the opportunity to:

- **Participate in design reviews** — contributing our experience with biometric key derivation, X.509 delegation architectures, and proxy-based enforcement to the NCCoE's architectural evaluation process
- **Answer technical questions** about our biometric entropy-to-key-derivation technology as it pertains to its utility as a root of trust for AI agent authorization — its properties, its certification basis, its ability to create a trust chain that intersects with FIDO platform authenticators, and its practical limitations
- **Provide demonstrations** of the ZeroSentinel architecture — biometric signing ceremonies, delegation credential issuance, proxy enforcement, cascading revocation, and classification-aware data flow controls — in whatever format the NCCoE finds appropriate

We are a small company with a specific technical contribution. We do not presume to define the demonstration project's scope or direction. If the NCCoE determines that biometric key derivation and cryptographic human-authorization are relevant to its objectives, we are ready to contribute. If the project takes a different direction, we hope this response and the attached white paper are useful reference material regardless.